

The IAM Product Selection and Decision Framework

After sufficient due diligence, requirements definition, and planning, a decision to evaluate a technology component of the desired solution can be considered. Prior to bringing in vendors and beginning product demonstrations, it is prudent to have a solid understanding of what you want the tool to enable and a prioritization of requirements to help form the basis of evaluation criteria for a given vendor. A decision framework for product evaluation and selection is a useful and important tool to leverage not just to make an informed decision but a defensible one. In a climate of ever tightening budgets where organizations are being forced to do more with less, business will continue to hold IT leaders accountable for not just fixing the short-term business problems but making an informed and cost-effective decision for long-term sustainability. These decisions and the decision-making process should be a transparent one. It should provide the business and other key stakeholders insight into how the tool of choice will enable a business outcome but also sustain it over time. The framework depicted in **Figure 17.1** can be used to both evaluate vendors and help secure the necessary business sponsorship and adoption in the organization when implemented.

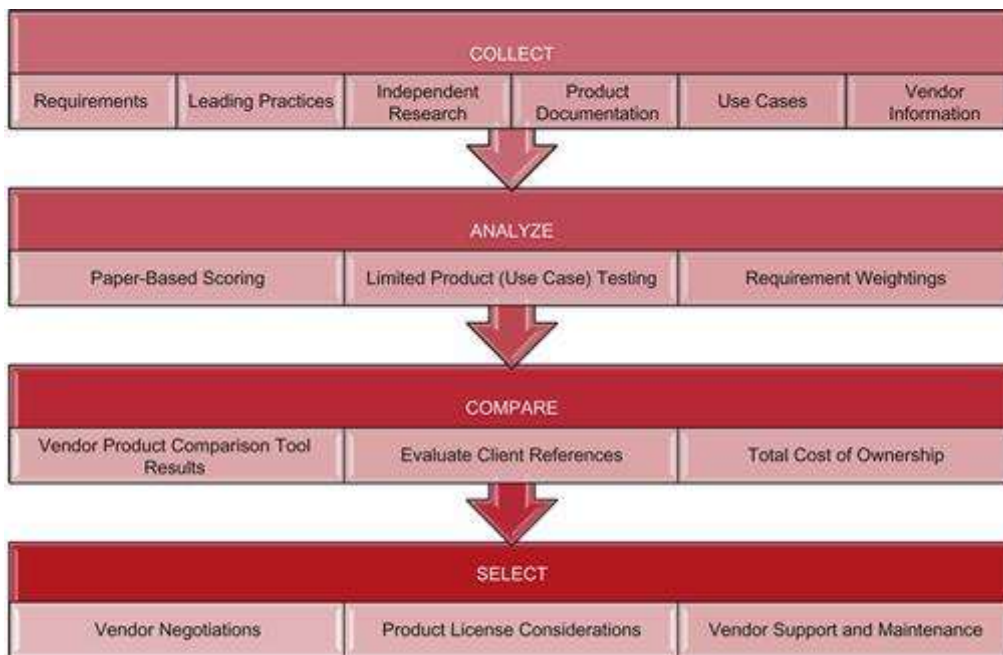


FIGURE 17.1 IAM product selection and decision framework.

Collect

The goal of the collect component of the framework is to conduct due diligence and collect the necessary requirements to form the basis of the evaluation criteria and use it as an input for later phases of the framework. At this point, the focus should be exclusively on information gathering and gaining input from key stakeholders—both business and technical.

Requirements

Requirement gathering is a critical step in the “Collect” process. Care should be taken to find the right balance of input from various business units, technical groups, and other stakeholders such as enterprise architecture, compliance, audit, legal, and risk functions. Depending on the size of your organization and the amount of stakeholders required to seek input from, this step can be one of the most time-consuming areas of the product selection process. After an inventory of requirement sources and groups has been established, facilitated workshops with key individuals can be scheduled to capture input and requirements. The requirements themselves can be in multiple flavors. Below is a list of the minimal types of requirements that can be considered in an effective IAM product selection process:

- Business requirements

- Technical requirements

- Functional requirements

- Nonfunctional requirements

All requirements should be collected in a consistent manner and stored centrally for later analysis. In some organizations, a requirement traceability matrix has been successfully used from the time of the product selection process to the completion of the product implementation.

The individual identifying a requirement should also be asked to categorize the requirement by importance (e.g., Low, Medium, High, Nice to Have, Must Have). Requirements should be given an identifier and labeled with meaningful “meta-data” (data about data) for traceability purposes. For example, capturing the business unit, the source (person or a unique identifier for a person), and the category (e.g., reconciliation, enforcement) is helpful to provide full traceability and will aid later analysis.

Requirement gathering efforts are much like detective work at a crime scene; careful handling and logging of the available evidence is critical for it to be useful later on in the product evaluation process. It is not uncommon for key stakeholders to ask for the source of the requirements, particularly when prioritizing the final requirements list for validation. As such, it is important to manage high-quality requirements documentation with full traceability and keep it up to date.

Business Requirements

Business requirements are derived from needs, features, and/or functions required for the IAM solution to be of value to the business. In most cases, the business will have limited interest in the technical requirements of

the tool and limited focus on the details of the back end infrastructure required to support it. Further, the business and most nontechnical stakeholders will likely describe what problems they have today rather than a specific requirement needed for an IAM solution.

Developing business requirements often necessitates a translation of a “voice of the customer (business)” survey. Requirements will ultimately be prioritized and evaluated to help pick the best tool to support the need. **Figure 17.2** depicts both a top-down and bottom-up requirement gathering methodology that can be tailored to fit the need. This hybrid approach to requirement collection provides for both high-level business requirements and lower level technical requirements.

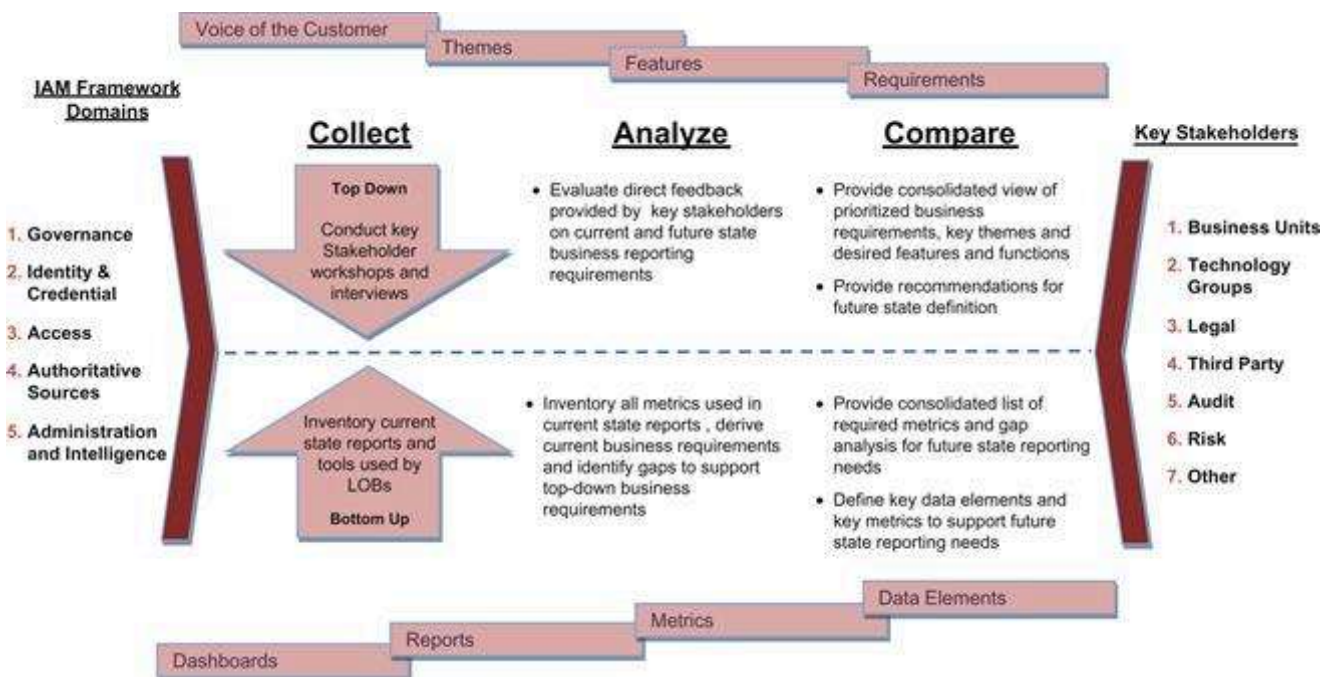


FIGURE 17.2 Hybrid approach to requirement collection.

The example provided above follows the IAM product selection and decision-making framework. It is an illustrative example of how a hybrid approach to requirement gathering can afford the right balance of detail from all stakeholders involved. As noted above, business requirements may need to be distilled prior to being listed as requirements for validation. Validation is a key quality control step that will minimize any loss of information during capture through interpretation into final business requirements. To assist with this translation, the reader is invited to consider the following sample voice of the customer to business requirement translation approach as depicted in **Figure 17.3**.

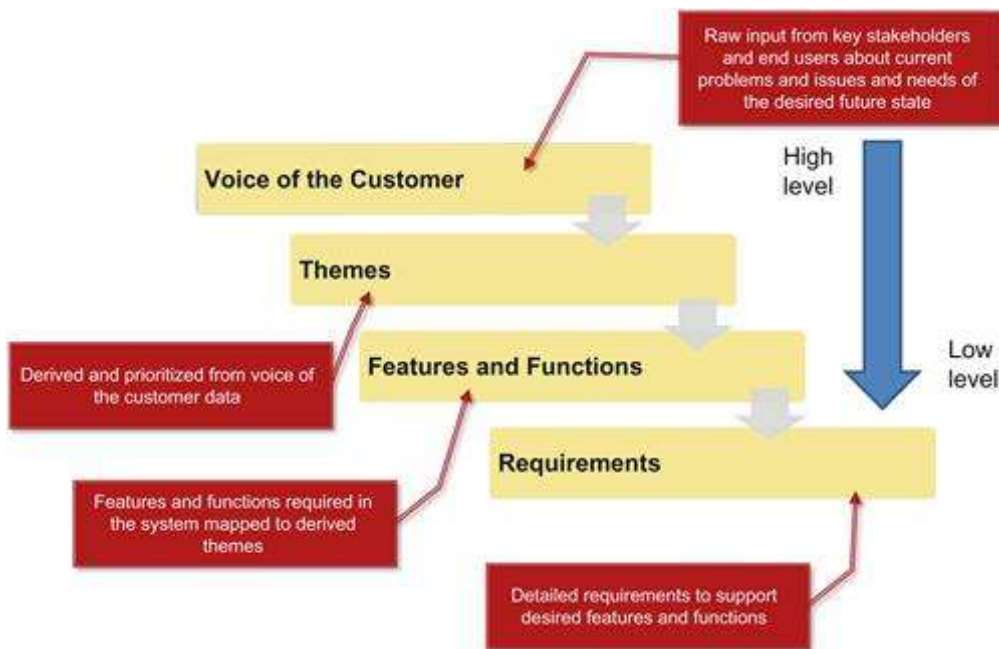


FIGURE 17.3 Sample approach to translating high-level customer feedback into requirements.

Using the approach outlined above, raw input in the form of the voice of the customer is grouped into key themes. Key themes are then broken down into specific features and functions that the IAM tool will be required to support. These features and functions are further broken down into requirements that can be brought back to the customer for validation and later used in the product evaluation process. Illustrative examples and excerpts of business requirements, taken from the enclosed IAM product comparison tool, are shown in [Figure 17.4](#).

				Product A		
				Weight (%)	Score: 1 - Low 2 - Medium 3 - High	Weighted Score
BUSINESS REQUIREMENTS						
ID	Request and Approval	Critical Path Testing?	13.0%	↔	2.0	0.26
RR01	Request and approve access by role		1.3%	↔	2.0	0.03
RR02	Standardized request processes		1.3%	↔	2.0	0.03
RR03	Role request status		1.3%	↔	2.0	0.03
RR04	Flexibility to request exceptions to roles		1.3%	↔	2.0	0.03
RR05	Role access request on behalf of others		1.3%	↔	2.0	0.03
RR06	Role-based routing of role access requests		1.3%	↔	2.0	0.03
RR07	Multiple-level role request approval		1.3%	↔	2.0	0.03
RR08	Role request approval - Notification		1.3%	↔	2.0	0.03
RR09	Role request approval - Delegation		1.3%	↔	2.0	0.03
RR10	Role request approval - Escalation		1.3%	↔	2.0	0.03
ID	Provisioning / De-Provisioning	Critical Path Testing?	5.6%	↔	2.0	0.11
RR16	Day One provisioning		1.4%	↔	2.0	0.03
RR17	Modifications to user access		1.4%	↔	2.0	0.03
RR21	Manual provisioning notifications		1.4%	↔	2.0	0.03
RR22	Manual provisioning reminders		1.4%	↔	2.0	0.03
ID	Enforcement	Critical Path Testing?	21.2%	↑	2.6	0.54
RR23	SoD analysis - Role definition		1.4%	↔	2.0	0.03
RR24	Preventative SoD checks - Role request	Use Case 5	1.4%	↔	2.0	0.03
RR25	Preventative SoD checks - Role assignment	Use Case 5	1.4%	↔	2.0	0.03

FIGURE 17.4 Illustrative examples of IAM business requirements.

Technical Requirements

Technical requirements are lower level requirements that will be specific to technical attributes and considerations of the desired tool. Technical requirements are gathered in a bottom-up fashion as depicted in the hybrid approach to requirement gathering discussed earlier. Technical requirements will require subject matter advisors and should be verified and validated with technical domain experts, as required. Illustrative examples and excerpts of technical requirements, taken from the enclosed IAM product comparison tool (booksite.elsevier.com/Identity_and_Access_Management), are shown in **Figure 17.5**.

HOME FUNCTIONAL NON-FUNCTIONAL BUSINESS			Weight (%)	Score: 1 - Low 2 - Medium 3 - High		Weighted Score	Product A
							Comments
Provisioning Solution Integration							
TR13	Anticipated Performance Impact		3.0%	↑	3.0	0.09	During loading of user and entitlement data and Role Mining, Product A will perform slow if the appropriate hardware resources such as memory and CPU are not allocated. To make sure that there are no performance issues, first size the hardware based on number of users, roles, applications, and user transaction, then perform load and stress testing and monitor the various components such as memory, CPU cycles, network traffic, database utilization and Product A application.
TR14	Standards Based		1.2%	↑	3.0	0.04	Product A support standards such as HTTPS and JDBC
TR15	API Support		6.0%	↑	3.0	0.18	Product A has standard base API support for integration with any external system such as the provisioning or entitlement system.
TR16	Support for Integration with Multiple Provisioning Tools		3.0%	↑	3.0	0.09	Product A can be integrated with OIM, Sun IdM, IBM Tivoli IdM and CA IdM.
TR17	Web Services Support		4.8%	↑	3.0	0.14	Product A has Web Service capability that can perform User Services such as Searching Users, Creating and Updating Users, Role Service such as retrieving roles for a user, assigning and deassignment of roles from a user, and Audit Service such as preventative SoD whereby a user requesting a role from a third-party system can first be verified against Product A for any SoD.
TR32	Batch Integration Support		7.2%	↔	2.0	0.14	Product A supports Batch Integration via multiple options. One option is to schedule a batch export process and export the data into a Flat File or into a database table. But this option requires some custom coding and configuration.
Connectors							
TR18	Flat File	Use Case 1	9.0%	↑	3.0	0.27	Product A do support Flat File import, this is the only method used for importing user and entitlement data.
TR19	UNIX		3.0%	↔	2.0	0.06	Product A do not have any connector for UNIX to import entitlement from this resource, the data needs to be extracted to a flat file, and then import it into the product. This flat

FIGURE 17.5 Illustrative examples of IAM technical requirements.

Functional Requirements

Functional requirements are those requirements related to the behavior of the IAM tool. Functional requirements provide insight into the ease of the interface and ability to perform key processes required of the IAM tool. Functional requirements are gathered and derived in the same ways as noted above. Illustrative examples and excerpts of functional requirements, taken from the enclosed IAM product comparison tool, are shown in [Figure 17.6](#).

HOME ROLE FUNCTIONAL TECHNICAL BUSINESS			Weight (%)	Product A		
				Score: 1 - Low 2 - Medium 3 - High	Weighted Score	Comments
FUNCTIONAL					2.93	
ID	Role Engineering	Critical Path Testing?	23.1%	↑	3.0	0.69
Role Modeling and Mining						
FR01	Business Role Modeling (Top-Down "Modeling")	Use Case 2	3.3%	↑	3.0	0.10
FR02	Ability to Perform Role Quality Analysis		3.3%	↑	3.0	0.10
FR03	User Friendly Interface for Role Modeling	Use Case 2	3.3%	↑	3.0	0.10
FR04	Ability to Map Business Roles to IT Roles	Use Case 2	3.3%	↑	3.0	0.10
FR05	Attribute Customization		3.3%	↑	3.0	0.10
FR06	IT Role Mining (Bottom-Up "Mining")	Use Case 2	3.3%	↑	3.0	0.10
FR07	Support for Creating Candidate Mined Roles		3.3%	↑	3.0	0.10
ID	Role Request and Approval	Critical Path	12.8%	↑	3.0	0.38

FIGURE 17.6 Illustrative examples of IAM functional requirements.

Non-functional Requirements

Nonfunctional requirements are those requirements related to IAM tool operation as well as additional business considerations not captured as core business requirements. Nonfunctional requirements provide insight into the ease of implementation, documentation quality, and other considerations about the vendor and vendor's solution. Nonfunctional requirements are gathered from internal stakeholders, independent research, product references, and third-party advisors. Illustrative examples and excerpts of nonfunctional requirements, taken from the enclosed IAM product comparison tool, are shown in [Figure 17.7](#).

HOME FUNCTIONAL TECHNICAL BUSINESS			Weight (%)	Product A			Comments
				Score: 1 - Low 2 - Medium 3 - High	Weighted Score		
NR08	Ease of Implementation		2.5%	↑	2.5	0.06	Product A can be deployed fairly quickly if the right resources, both infrastructure and people, are allocated to the project. The complexity increases loading the user and entitlement data into Product A, and integration with OIM.
NR09	Training		2.5%	↑	2.5	0.06	Oracle University offers Product A product training both virtual and instructor lead.
NR10	Vendor Support Availability		10.0%	↑	2.5	0.25	Oracle offers 24x7 customer support by combining both onshore and offshore support centers.
NR11	Documentation Quality		2.5%	↔	2.0	0.05	Product A has documentation help files and product documentation, but some of the more advanced features were difficult to gather information for.
NR12	Licensing Options		2.5%	↑	3.0	0.08	Product A is licensed by number of active users.
NR13	Language Support		2.5%	↑	3.0	0.08	Product A supports multiple language packs and can be easily configurable to display text in different languages.
NR14	Branding Customization	Use Case 10	2.5%	↑	3.0	0.08	Client branding was easily configurable in Product A by changing style sheets and images.
NR32	Product Alignment with BAC Direction		5.0%	↑	3.0	0.15	Product A is able to support BAC RBAC requirements.
NR33	Availability of Trained/Experienced Resources in the Market		10.0%	↔	2.0	0.20	Experience resource with Product A skill sets are not readily available. The original company (Yauu) that developed Product A, had only between 70-95 resources. After Sun acquired Yauu, most of these resources left Sun and started smaller consulting business specializing in deployment of Product A. After Oracle acquired Sun, most of the remaining resources that had the expertise in Product A left and joined other organization.
ID	Role Auditing	Critical Path Testing?	7.5%	↑	3.0	0.23	

FIGURE 17.7 Illustrative examples of IAM nonfunctional requirements.

Leading Practices

Leading industry practices are helpful and important considerations to include as part of the product evaluation and selection process. IAM tools are designed to operate in a particular way; however, one vendor is typically able to supply the entire tool portfolio required to support a leading IAM capability at a given organization. Sometimes this is driven by available functionality; sometimes you may desire not to have a single vendor or a single point of failure. As such, understanding integration points of leading tools as well as forward looking technology roadmaps and alignment with open standards should be considered so that the tool that you ultimately select does not just fill a short-term need but can support a broader, future state, and strategic vision.

Independent Research

Independent research and reviews of leading IAM tools are available in many industry analyst reports and may be obtained from technology advisory and implementation companies. This information can provide a wealth of helpful insight and save your organization a significant amount of research time. That said, it is important to form your own opinions about the vendors and the tools they support; independent advisors can be used as an aid to form these objective opinions but should not be solely depended on.

Product Documentation

Collection of product documentation, as part of the evaluation process, can be used as helpful reference material as part of your requirement gathering efforts. That said, vendor supplied product documentation should not be considered independent and care should be taken before accepting that a feature, function, or support for a given connector (for example) is available in the generally available release.

Use Cases

After requirements are gathered and prioritized, a select number of key use cases should be identified and defined in preparation for head-to-head product analysis. Use cases can be selected that are both possible and practical to conduct over a time-boxed effort, a maximum of a 4-week period. Vendors will typically provide a 30-day trial period for which the user can independently test and evaluate their tool without cost. Use cases that need more than 4 weeks should be discouraged unless there is a specific critical functionality that is required to see demonstrated in the local environment. Other considerations such as required hardware, custom data connectors, and data stores may also be required to adequately test use cases for each of the vendors under analysis. Use cases should define the parameters of what will be tested, in what order, and with defined success and failure criteria. Care should be given so that use cases are equally applied and tested for each vendor. **Figure 17.8** provides an illustrative description of key use cases defined in a role-based access control tool evaluation.

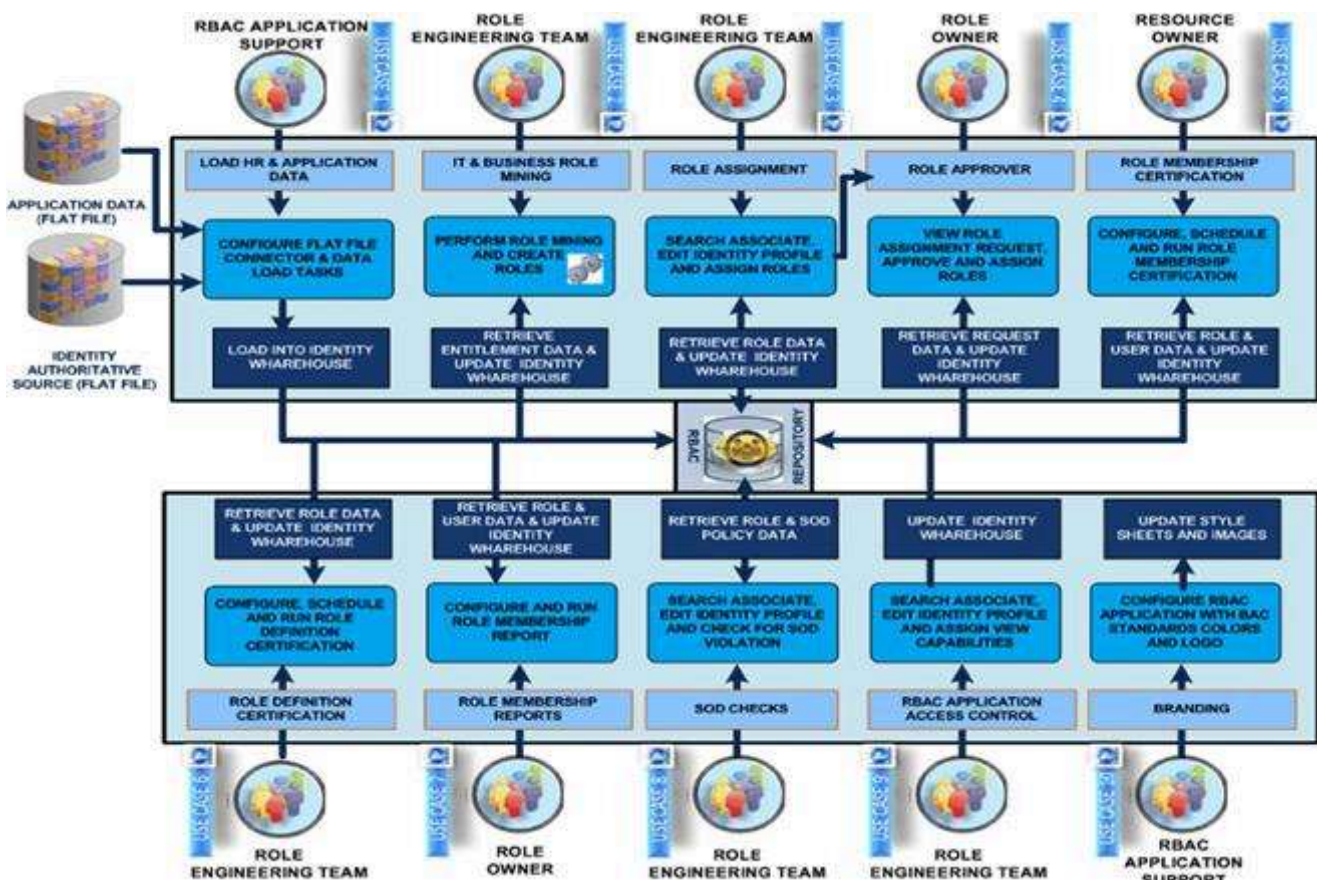


FIGURE 17.8 Examples role-based access control (RBAC) use cases.

Vendor Information

Vendor information such as strength of the company, time in the market, overall product roadmap and strategy, your organization's history and buying power with a given vendor, could all be elements of consideration in your vendor and product selection process. While the goal of evaluation exercise is to choose the best tool for the best price, you are also choosing a relationship with a vendor. Due diligence should be conducted to minimize the risk of choosing and getting stuck in a relationship with a challenging vendor relationship.

Analyze

The goal of the analyze component of the IAM product selection and decision framework is to arrive at an aggregate evaluation score that allows the organization to select a tool (and vendor) that best meets the needs of the organization's requirements. In the analyze component, several vendors are selected for head-to-head comparison analysis based on the established requirements and select use cases. The IAM product comparison tool discussed in earlier sections and available as part of this book, serves as a convenient tool to analyze and report out on vendor evaluation results. The tool requires the user to provide their organization's prioritized business, technical, functional, and nonfunctional requirements and associated weightings. Once the tool is set up with this information, it can be used to provide a fair and balanced head-to-head evaluation of each product. Independent nonvendor affiliated entities such as technology advisory companies can be considered to perform the product evaluation and head-to-head comparison analysis on behalf of the organization. **Figure 17.9** provides an illustration of the tool interface.

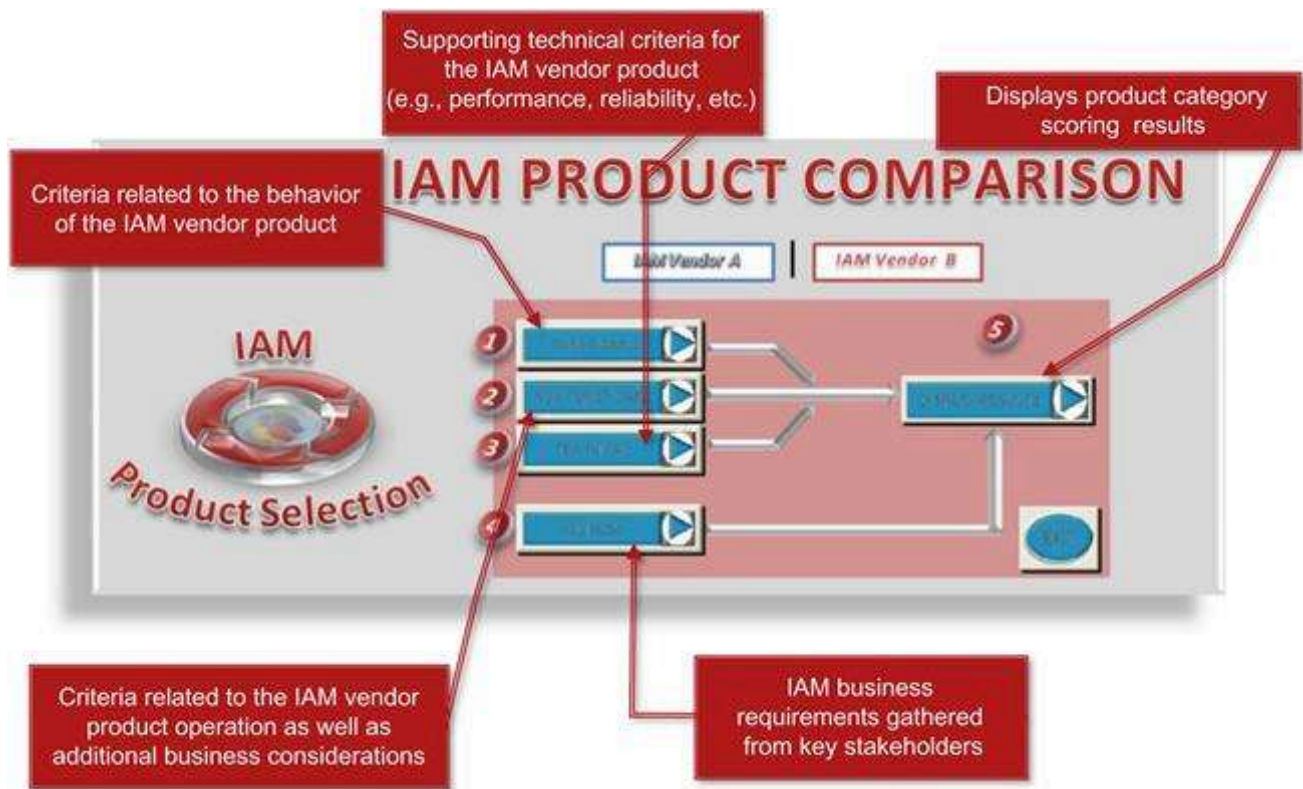


FIGURE 17.9 IAM product comparison tool.

Paper-Based Scoring

Paper-based scoring is a technique used (within the IAM product comparison tool) to evaluate requirements based on data available in print and independent references as opposed to live testing done in use case analysis. Paper-based scoring is not as definitive as live testing and evaluation in a proof of concept or pilot environment. That said, paper-based scoring analysis does provide the organization a basic level of analysis in a cost-effective and efficient manner.

Limited Product (Use Case) Testing

Use case testing as described previously provides actual product analysis through use of the tool in a test environment and designed to test the adequacy of the vendor tool against the success or failure criteria of the defined use case. Use cases should have been selected to test the most critical and important functionality against the organizations requirements (as practical). As such, use case testing should be weighted heavier to that of the requirement analysis provided via paper-based scoring methods.

Requirement Weightings

Requirement weightings are applied to requirements to denote higher priority and importance; the higher the relative weighting, the higher the result of the evaluation for that requirement will factor in the overall

analysis and comparison report. **Figure 17.10** provides an illustration of the IAM product comparison tool interface and explanations of how weightings are calculated.

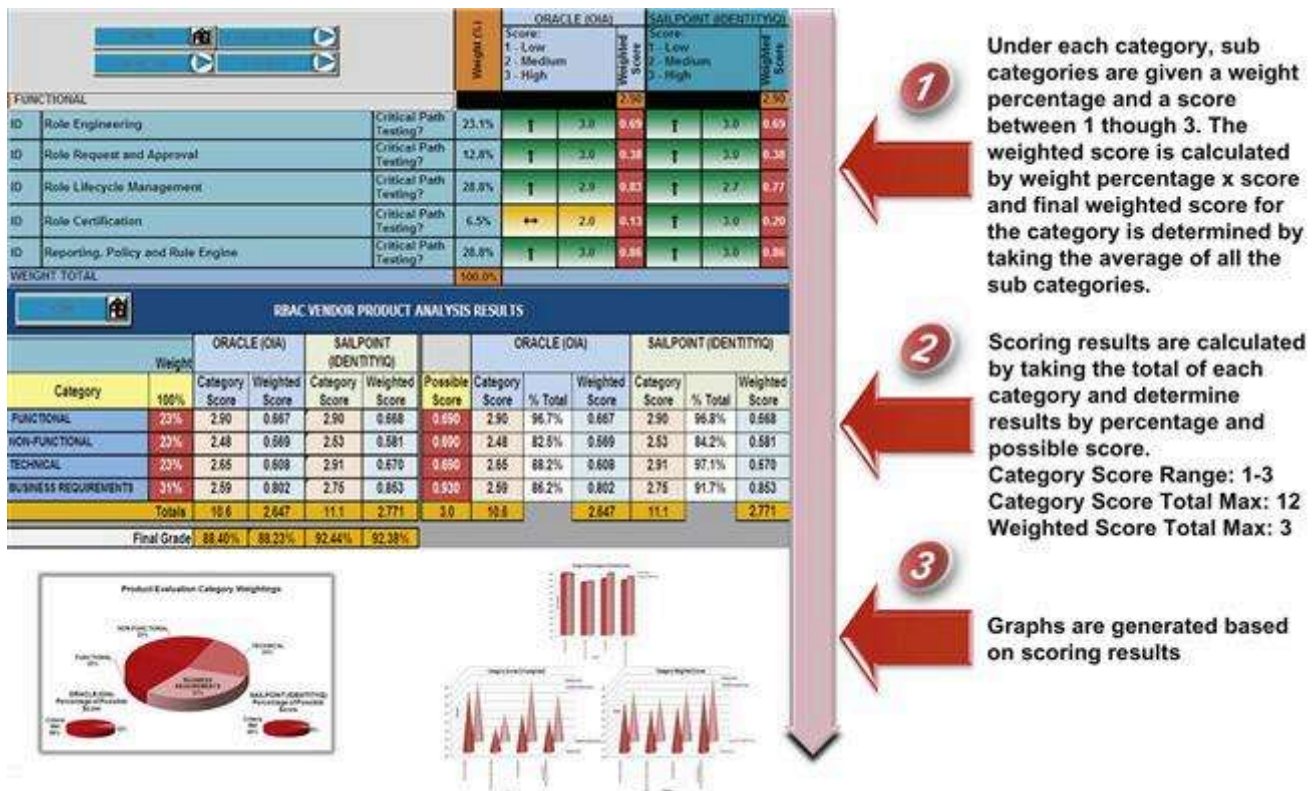


FIGURE 17.10 Requirement weightings within the IAM product comparison tools.

Compare

In the compare element of the IAM product selection and decision framework, IAM products are compared based on predefined categories and scoring weightings as defined in the analyze section discussed earlier. The following sections are fairly straightforward; the reader can use the IAM product comparison tool that accompanies this book to leverage the scoring mechanisms and available summary tables and reports that graphically depict results of the tool comparison activities.

Vendor Product Comparison Tool Results

The IAM product comparison tool provides graphical analysis of weighted results based on the tool setup. These charts and graphs provide an easy to interpret and understand view of each product compared to each other and against a total possible score (100% coverage for all requirements). **Figure 17.11** is an illustrative example of available analysis provided in the product comparison tool.

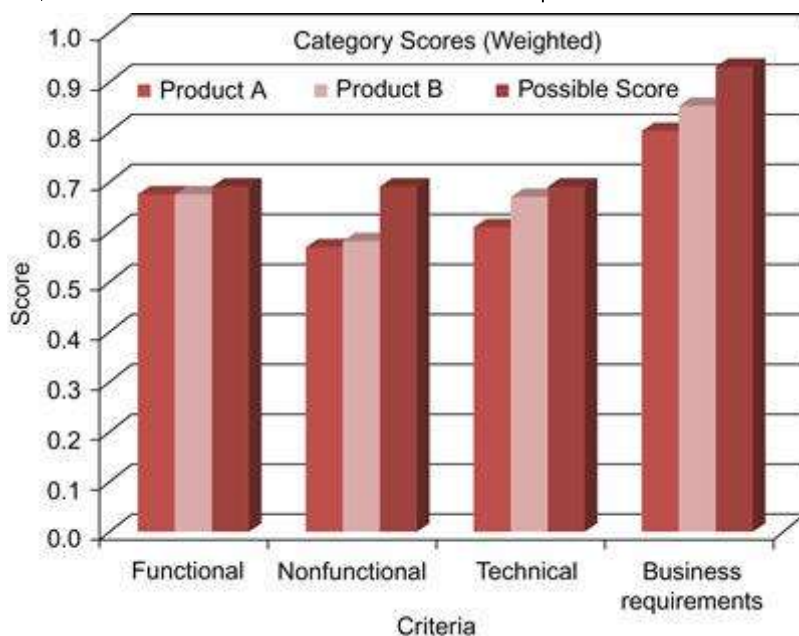


FIGURE 17.11 IAM product comparison output.

Evaluate Client References

Client references are perhaps one of the most important validations of what a product is documented to do versus what it actually does in a true production environment. A vendor without references you can speak with (without the vendor on the call) can be an indicator that the vendor's marketing material may be more real than the product's advertised features and functions. Lack of references can also mean that the product may not have been on the market for very long. In either case, buyers should be wary of vendors without references. Organizations should ask for two to three references in the same industry and of similar scope and size. As mentioned earlier, reference calls should be set up between your organization and the reference client, independent of the vendor, which provides for a candid and direct conversation. The buyer organization should leverage the requirement analysis and comparison data to validate expected results in production at the reference organization. Further, the buyer should take time to prepare a list of questions ahead of time so that the time on the reference call can be time well spent for both parties. A consistent approach to reference calls helps compare data and feedback obtained from the multiple references and factored into the overall analysis.

Total Cost of Ownership

Total cost of ownership (TCO) of a particular IAM technology is often overlooked and often underestimated or confused with the direct costs associated with licensing, support, and services costs. TCO for IAM solutions consider not only just initial capital technology costs but also ongoing people, licensing, and maintenance process costs. An access management TCO evaluation tool (a link to the digital materials) is provided in this book. The reader is encouraged to evaluate the TCO of a given software product, prior to purchase. TCO also provides the organization's management with a full view of the costs (and savings)

associated with implementing a given IAM solution. It is left to the reader to determine their own TCO for a given IAM solution; however, below are key areas of consideration that when looked at in the aggregate, make up a more comprehensive picture of TCO for an organization:

- Technology costs
- Software licensing costs
- Software maintenance costs
- Hardware costs
- Integration costs
- Implementation costs
- People costs
- Implementation labor costs
- Annual operations and support costs
- Annual training costs
- Process costs
- New process creation costs
- Process reengineering costs
- Updates to policies and procedures

Select

As discussed earlier in the collect, analyze, and compare elements of the IAM product and decision framework, selecting a vendor should be based on a number of factors. Once a decision is made relative to how best the vendor can meet your organization's requirements, risk tolerance, and overall cost of ownership, it will be time to negotiate for the most favorable contract possible. The following sections provide insight

into key consideration from the vendor's perspective to help the reader and their organization negotiate for the best terms possible while managing product support risk.

Vendor Negotiations

Vendor negotiations can be tricky business. Depending on the size of your company and existing contractual relationships such as master licensing or ongoing maintenance agreements, you may be afforded additional leverage in negotiations that should be used to your advantage. Further, your procurement team or global sourcing department will likely have experience in software negotiations that should also be explored and used to the fullest extent. The following are a list of other considerations that can be used to your advantage when negotiating large software licensing and maintenance agreements. This list is by no means exhaustive but should serve as a helpful guide in your current or future negotiations.

■ **Size of the vendor:** The vendor may be a large established organization, a small start-up or somewhere in between. The size, history, and overall agenda of the vendor can all work to your advantage. Large organizations will typically have deeper discount ability than smaller vendors and will likely have other products or services they would like to position. Smaller vendors or start-ups are generally looking to establish a beachhead at a company or gain a well-known brand or product reference to establish their credibility in the market.

■ **Sharing development costs:** Many smaller vendors have a niche product with a core team of developers. Scaling to support the needs of a large organization can be challenging. As such, service-level agreement components should be negotiated accordingly. For example, it's not unusual to place source code in escrow as a precaution in case the vendor goes out of business. Newer products may also lack sufficient scalability testing; entering into an agreement with a newer vendor in a beta capacity to provide testing support can be risky but can afford deep savings on future licensing commitments. Contractual negotiations should consider these possibilities and language designed to protect your investment should be included in the agreement (e.g., source code escrow).

■ **Vendor client references:** References are valuable to vendors of all sizes; small- to medium-sized companies may be looking for references from clients of all types and sizes to support future sales in a variety of markets. Larger companies will look to increase their market share and build their brand. If the historical consolidation of the IAM software market serves as a guide, small- to medium-sized companies will likely be acquired by bigger ones. Agreeing to be a reference client will typically obligate your company to have your brand be displayed on the vendor's marketing material or commit your company to a predefined number of reference calls with other prospects. These obligations will require the appropriate approvals from your organization and do come with some risk (e.g., if the software product does not work, is on the news for having a major security breach). That said, agreeing to be a reference, assuming the software solution lives

up to what it was designed to do for your organization, can afford your organization additional discounting; extreme care and caution is recommended before contract obligating your company.

■ **Timing of the purchase:** Vendor revenue for new software purchases is typically recognized when software is shipped (physically or electronically). As such, the vendor will take credit for the sale on its books in the month that the software has been shipped after the software licensing agreement and other contracts (as required) are signed. Software vendors are typically more inclined to make better deals and take on deeper discounts toward the end of a month, end of quarter, or end of their fiscal year. As such, it is important to understand when your vendor's fiscal year starts and ends and time your negotiations accordingly.

Product License Considerations

It is important to understand the full terms and conditions of your software licensing agreement. Some vendors have the right to audit your organization to determine the amount of software your organization is using and if you are in violation to the amount of licenses available in your contract. Compliance infractions can be very costly and work against your organization in future renewal negotiations. As such, it is important to have a perspective on future licensing needs and to the extent possible, negotiate the price of these future needs up front as to lock in the software license rate. This can be an addition to or an alternate to deeper discount on price. Similarly, a credit should be available if the buyer organization does not use all required licenses.

Vendor Support and Maintenance

Vendor support and maintenance is an often overlooked component in vendor negotiations. IAM software and related technology is often employed to mitigate risks or increase productivity. IAM software support is critical to ensure proper coverage and ongoing operations. In the event of a significant failure, the organization will need access to the vendor's top support staff and in some cases its most experienced developers. Your existing relationship with the vendor of choice can be important to expedite or escalate such services but it should not be the only protection you have to obtain the prioritized support you may need. As such, your software contract should explicitly define the terms of the support coverage required or the service levels to be employed based on level on priority. Many software vendors will charge for premium service levels; this may be an important consideration for your organization to obtain or negotiate as part of the initial purchase.

Conclusion

In summary, in this chapter we examined the key elements and processes of the IAM product selection and decision framework. Further, we discussed the high probability of failure in evaluating an IAM technology-

based solution without a firm understanding of the IAM processes, policies and key business, technical, functional, and nonfunctional requirements necessary to map the organization's needs to the desired tool. This chapter provided a number of tools and techniques, to help collect, analyze, compare, and select the best solution available. The reader is strongly encouraged to leverage the tools and content supplied in this chapter and “measure twice and cut once” to avoid costly pitfalls.